2-й участник. Классификация DoS/DDoS-атак по 6 пунктам

Классифицировать DoS и DDoS-атаки можно по нескольким признакам. Для доклада удобно использовать 6 пунктов.

1. По количеству источников атаки

Первый критерий — откуда идёт вредоносный трафик.

DoS-атака идёт из одного источника или небольшого числа источников. Например, один сервер отправляет слишком много запросов на сайт жертвы.

DDoS-атака идёт из множества источников. Это может быть ботнет из заражённых компьютеров, роутеров, камер, серверов или IoT-устройств. Именно поэтому DDoS сложнее отражать. Если заблокировать один IP-адрес, атака продолжится с тысяч других адресов.

Почему такая классификация важна: способ защиты зависит от количества источников. Против DoS может помочь локальная блокировка. Против DDoS обычно нужна защита на уровне провайдера, CDN, WAF, облачной инфраструктуры или специализированного анти-DDoS-сервиса.

2. По уровню сетевой модели OSI

Второй критерий — на какой уровень системы направлена атака.

Атаки уровня L3 направлены на сетевой уровень. Они могут перегружать IP-инфраструктуру и сетевое оборудование. Cloudflare отдельно описывает L3 DDoS как атаки, которые обычно используют сетевые протоколы и нацелены на инфраструктуру, а не на конкретную веб-страницу.

Атаки уровня L4 направлены на транспортный уровень. Типичный пример — SYN flood, когда злоумышленник создаёт множество незавершённых TCP-соединений. Сервер резервирует ресурсы под эти соединения и постепенно перестаёт обслуживать нормальных пользователей.

Атаки уровня L7 направлены на прикладной уровень. Например, HTTP flood создаёт множество запросов к страницам сайта, API или форме авторизации. Такие атаки особенно неприятны, потому что каждый запрос может выглядеть как обычный запрос пользователя. Cloudflare описывает application layer DDoS как атаки на верхний уровень модели OSI, где обрабатываются HTTP GET и POST-запросы.

Почему эта классификация важна: защита от L3/L4 и L7 разная. L3/L4 чаще требуют сетевой фильтрации, anycast, анти-DDoS у провайдера. L7 требует WAF, rate limiting, анализа поведения пользователей, кэширования и защиты конкретных endpoint'ов.

3. По типу перегружаемого ресурса

Третий критерий — что именно пытаются исчерпать атакующие.

Первый вариант — пропускная способность канала. Это volumetric attack. Цель — забить интернет-канал так, чтобы легитимный трафик не доходил до сервера.

Второй вариант — ресурсы сетевого оборудования. Например, таблицы соединений firewall, балансировщика или маршрутизатора.

Третий вариант — ресурсы приложения. Например, процессор, оперативная память, база данных, очередь задач, пул соединений к БД. L7-атаки часто опасны именно этим. Один тяжёлый запрос может стоить серверу больше ресурсов, чем атакующему.

Почему это важно: если атака забивает канал, бессмысленно пытаться лечить только приложение. Нужно фильтровать трафик выше по сети. Если атака бьёт по базе данных, нужно защищать конкретные запросы, кэшировать ответы и ограничивать дорогие операции.

4. По механизму создания нагрузки

Четвёртый критерий — каким способом создаётся перегрузка.

Прямой flood — когда источники атаки напрямую отправляют большое количество пакетов или запросов к цели.

Reflection/amplification — отражённая атака с усилением. В этом случае атакующий использует сторонние серверы или протоколы, чтобы увеличить объём трафика, приходящего к жертве. Например, DNS amplification или NTP amplification. Cloudflare относит такие атаки к volumetric DDoS, где цель — заполнить доступную полосу пропускания большим объёмом трафика.

Botnet-based attack — атака через ботнет. Это самый характерный сценарий для DDoS: множество заражённых устройств получают команды и начинают генерировать трафик.

Почему это важно: при прямом flood можно фильтровать источники. При отражённой атаке важно понимать, что трафик может идти от внешне легитимных серверов. При ботнете сложность в том, что источники распределены географически и технически.

5. По длительности и динамике атаки

Пятый критерий — как атака развивается во времени.

Кратковременная атака может длиться минуты. Её цель — быстро вывести сервис из строя, сорвать мероприятие, матч, продажу билетов, онлайн-экзамен или запуск продукта.

Длительная атака может идти часами или днями. Она опасна тем, что выматывает техническую команду и увеличивает финансовые потери.

Импульсная атака идёт волнами. Например, 10 минут атаки, затем пауза, затем снова атака. Такой формат усложняет диагностику: система вроде бы восстановилась, но затем снова падает.

Почему это важно: разные сценарии требуют разного реагирования. При короткой атаке важна автоматическая защита. При длительной — нужен план дежурств, связь с провайдером, логирование, коммуникация с пользователями и контроль расходов на инфраструктуру.

6. По цели и последствиям

Шестой критерий — зачем проводится атака.

Цель может быть финансовой. Например, вымогательство: «заплатите, иначе сайт будет недоступен».

Цель может быть конкурентной. Например, атака на интернет-магазин во время распродажи.

Цель может быть политической или идеологической. Такие атаки часто называют хактивистскими.

Цель может быть отвлекающей. Пока команда занята DDoS, атакующий может пытаться провести другую атаку — например, фишинг, подбор паролей или эксплуатацию уязвимости.

Почему это важно: при DDoS нельзя смотреть только на доступность сайта. Нужно параллельно контролировать логи авторизации, попытки входа, изменения прав, подозрительные действия в админ-панели и внутренней сети.

Общий вывод второй части: DDoS нельзя описывать одной фразой «сайт завалили запросами». Нужно понимать источник, уровень атаки, механизм, цель, длительность и перегружаемый ресурс. От классификации напрямую зависит защита.